AUTHENTICATION, AUTHORIZATION & ACCESS CONTROL

Tokens, Passwords & Least Privilege

Introductory principles for session verification, credential storage protection, and scoped access boundaries.

Topic Module · Policarpio

PART 01 · TOKENS AT AN INTRODUCTORY LEVEL

What Are Authentication Tokens?

A digital access pass issued after login so users never resend their password on every page click.

- **Digital Wristband:** Proves identity across multiple requests.
- **Stateless Proof:** Carries signed user permission data.
- **Time-Limited:** Expires automatically to prevent theft.
- **Tamper-Evident:** Sealed via server cryptographic key.



PART 01 · TOKEN LIFECYCLE

How Token Authentication Works



STEP 01

User Login

Client submits valid login credentials.

STEP 02

Token Minting

Server signs cryptographic access token.

STEP 03

Client Storage

App stores token in memory.

STEP 04

API Access

Server verifies token every request.

PART 01 · TOKEN STRUCTURE

Inside a JSON Web Token (JWT)

```
eyJhbGciOiJIUzI1NiJ9.eyJ1c2VyIjoiYWxpY2UiLCJyb2xlIjoicGxheWVyIn0.SflKxwRJSMeKKF2QT4fwpMeJf36POk6yJV_adQssw5c
```



1. Header (Red)

Specifies cryptographic signing algorithm.



2. Payload (Blue)

Contains user ID role expiration.



3. Signature (Green)

Prevents unauthorized payload modification.

PART 01 · TOKEN CATEGORIES

Access vs. Refresh Tokens

Access Token

- **Lifespan:** Short duration around 15 minutes.
- **Function:** Unlocks protected API endpoints.
- **Transmission:** Sent with every resource request.
- **Real-World Analogy:** Daily hotel room keycard.

Refresh Token

- **Lifespan:** Long duration spanning days.
- **Function:** Requests new access tokens silently.
- **Transmission:** Exchanged only at renewal server.
- **Real-World Analogy:** Front desk booking receipt.

Password-Handling Principles

Design for Breach Readiness

Secure systems assume attackers may eventually leak the user database.

Golden Mandate: Never store or log human-readable passwords.



PART 02 · CORE DEFENSES

Three Golden Password Rules



Zero Plaintext

Never store raw text passwords.



One-Way Hashing

Transform passwords into irreversible digests.



Unique Salting

Append random strings before hashing.

PART 02 · STORAGE COMPARISON

Hashing and Salting in Action

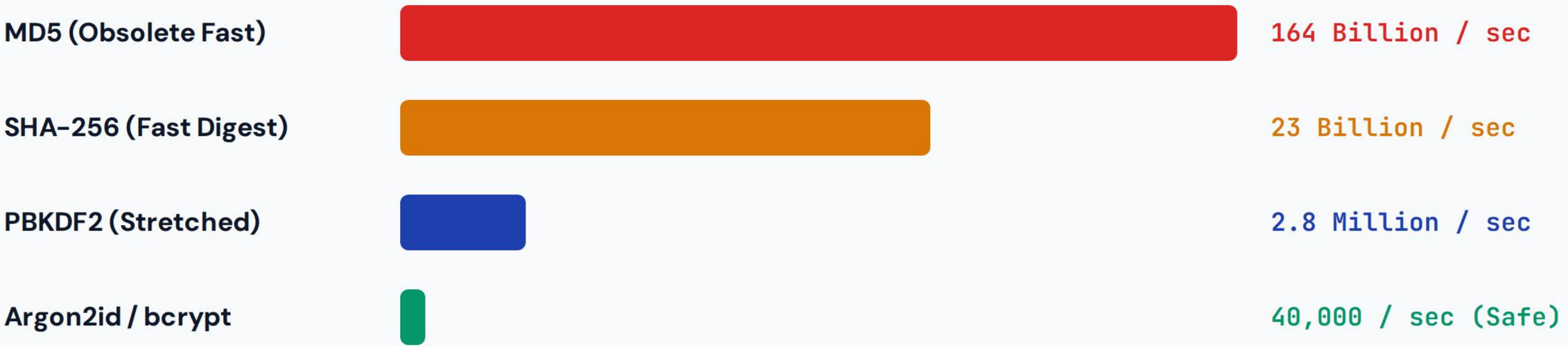
Database records when User A and User B both choose the identical password **"secret123"**:

Storage Technique	User A Stored Value	User B Stored Value	Protection Level
Plaintext	`secret123`	`secret123`	**Critical Exposure**
Unsalted Hash	`e99a18c428cb38d5 ...`	`e99a18c428cb38d5 ...`	**Rainbow Table Risk**
Unique Salt + Hash	`$salt9A$8c1f4e09 ...`	`$salt4X$2d9a7b33 ...`	**Industry Standard**

PART 02 · WORK FACTOR & KEY STRETCHING

Why Slow Hashing Matters

Offline attacker password guesses per second on modern GPU hardware (slower algorithms protect users):



PART 03 · PRINCIPLE OF LEAST PRIVILEGE

Principle of Least Privilege (PoLP)



"Grant every user or system process only the minimum rights required to complete its task."

- **Default Deny:** New accounts start with zero permissions.
- **Role Separation:** Split player moderator admin capabilities.
- **Time-Bound Access:** Revoke temporary elevation immediately.

PART 03 · ACCESS CONTROL IMPACT

Containing the Blast Radius

74%

of breaches involve human credentials or privilege misuse (Verizon DBIR).

Scoped System Boundaries

- **Player Account:** Saves personal game progress only.
- **Moderator Role:** Filters community chat only.
- **System Admin:** Configures core server infrastructure.

SUMMARY & KEY TAKEAWAYS

Securing Identity & Access

Tokens verify active sessions · Salted hashes protect stored passwords · Least privilege contains breaches

Thank You · Questions & Discussion

Image Sources



https://getsafeandsound.com/wp-content/uploads/2023/09/Badge-Access-Control.jpg

Source: getsafeandsound.com



https://media.easy-peasy.ai/bf4ccc70-bb21-41f1-9fe5-53dd6c6443b1/9895f0d8-52cb-413e-8c20-65784742eb3b_medium.webp

Source: easy-peasy.ai



https://www.genton.com.au/wp-content/uploads/2023/06/long-2-1-2399x1349.jpg

Source: www.genton.com.au